IT3070 • EXAM REVISION COMPANION

Access Control, User Authentication, Disaster Recovery & Network Security

සති 09–12 සඳහා සරල සිංහල විස්තර, English exam definitions, රූප සටහන්, worked examples සහ සම්පූර්ණ පිළිතුරු.



Bilingual Self-Study Handbook

Source-grounded to the uploaded lectures • Past-paper-adapted exercises • New 100-mark mock examination

Sinhala concepts | English questions & answers | A4 printable PDF

BEFORE YOU BEGIN

Study with a purpose

මෙහි English definitions සහ exam questions භාවිත කරන්නේ ඔබේ විභාගය English වලින් නිසායි. Sinhala paragraphs භාවිත කරන්නෙ concepts ඉක්මනින් තේරුම් ගැනීමටයි. ප්‍රශ්නයක් කියවූ පසු පිළිතුර බලන්න කලින් මතකයෙන් කියන්න හෝ ලියන්න.

Your examination format (from the notice)

Part 1: 35 questions / 35 marks • **Part 2:** 11 questions / 43 marks • **Part 3:** 3 questions / 22 marks

All 49 questions are compulsory. No calculators. The mock exam in this handbook follows the same numbers and total marks, while focusing on Weeks 9–12.

Contents

Week 09 – Access Control 3

Week 10 – User Authentication 8

Week 11 – DRP & Business Continuity 15

Week 12 – Firewalls & Network Security 21

Past-Paper-Adapted Question Clinic 29

100-Mark Mock Examination 33

Detailed Mock Answers & Explanations 40

Final Quick Revision & Glossary 47

How to use the handbook

1. Learn

Read Sinhala explanations and the English definition.

2. Visualize

Trace arrows, matrices, tables and timelines.

3. Apply

Solve every scenario before viewing the worked solution.

4. Recall

Attempt the full mock without notes, then mark it.

Study sources: uploaded Week 9 Access Control, Week 10 User Authentication, Week 11 DRP/BCP, Week 12 Firewalls/ACLs/ Network Security; access-control and authentication tutorial files; uploaded older IT3070 papers. Source citations and paper references are given in relevant chapter/exercise headings.

WEEK 9

Access Control

කවුද, මොන resource එකකට, මොන action එකක් කරන්න අවසර තියෙන්නේ?

Lecture source: Week 9 – Access Control, slides 3–22; Access Control Tutorial.

9.1 Why Access Control matters

හිතන්න University Examination Portal එකක් තියෙනවා. Student කෙනෙකුට තමන්ගේ marks බලන්න පුළුවන්. Lecturer කෙනෙකුට assigned course marks update කරන්න පුළුවන්. Admin කෙනෙකුට accounts manage කරන්න පුළුවන්. හැම user කෙනෙක්ම login වුණත්, අවසර වෙනස්. Access Control එකෙන් ඒ permissions enforce කරනවා.

> EXAM DEFINITION
>
> **Access Control is the prevention of unauthorized use of a resource, including unauthorized ways of using that resource (ITU-T X.800 definition given in the lecture).**

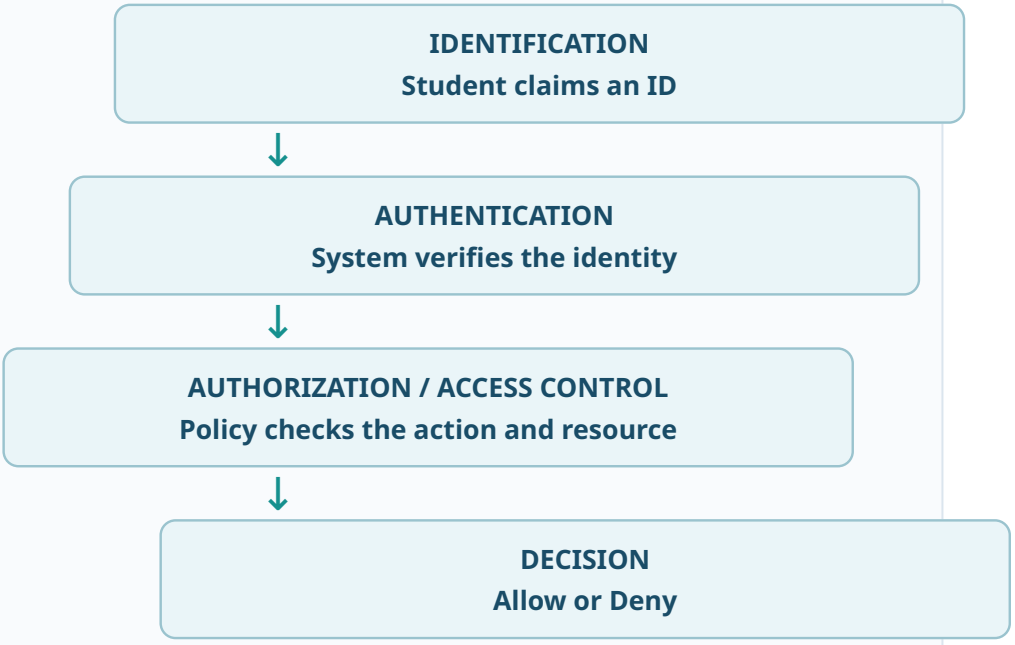


Figure 9.1 – Authentication establishes identity; authorization evaluates the requested action.

Element	Definition / example
Subject	User or process requesting access. Example: Lecturer
Object	Protected resource. Example: Marks.xlsx or database record
Access Right	Permitted operation. Example: Read, Write, Execute, Delete, Create, Search

Element	Definition / example
Authorization	Determining whether the subject may perform the action on the object

WORKED EXAMPLE · identify entities

A lecturer tries to update examination marks using the university portal. Identify the subject, object, and access right.

1. Who requests the operation? The lecturer.

2. Which resource is affected? The marks record.

3. Which operation? Write/Update.

Answer: {answer}

{explainer}

9.2 DAC, MAC and RBAC – choose the correct policy

DAC – Discretionary

Owner/authorized entity decides whether to share access.

MAC – Mandatory

System-controlled security classifications and clearances.

RBAC – Role-Based

Permissions assigned to roles; users inherit role permissions.

Coexistence

A system can use more than one of these models.

DAC: File owner කෙනෙකුට Bob ට Read permission එකක් දෙන්න පුළුවන් නම් DAC. **MAC:** Top Secret document එකක් read කරන්න Secret clearance විතරක් තිබෙන user ට අවසර නැත්නම් MAC. **RBAC:** Nurse, Doctor, Receptionist වැනි job roles අනුව permissions assign කරනවා නම් RBAC.

Model	Decision basis	Ideal scenario	Main limitation
DAC	Identity/owner discretion	Collaborative document sharing	Over-sharing by owners
MAC	Security label + clearance + policy	Classified research	Inflexible; complex labeling
RBAC	Role → permissions	Hospital, banking, university	Role explosion / excessive roles

MCQ trap

Week 8 **MAC = Message Authentication Code**. Week 9 **MAC = Mandatory Access Control**. Read the question context carefully.

WORKED EXAMPLE · policy choice

A hospital allows doctors to edit clinical notes, nurses to view care instructions, and clerks to manage appointments. Which policy best fits?

1. Recognize that access depends on job functions.

2. Permissions can be assigned to roles.

Answer: {answer}

{explainer}

9.3 Access Matrix: build it correctly

Access Matrix එකක **Rows = Subjects**, **Columns = Objects**, **Cells = Permissions**. Lecture slide 10 diagram එකට අනුව භාවිත කරන standard orientation එක මෙයයි. (Slide 9 prose එකේ row/column words swapped වූ තැනක් තිබුණත් diagram එකේ orientation එක මෙහි අනුගමනය කරලා තියෙනවා.)

User / File	Grades	Course Notes	Accounts
Student	R (own only)	R	—
Lecturer	R,W (assigned)	R,W	—
System Admin	— unless approved	— unless approved	R,W

WORKED EXAMPLE · allow or deny

Can a Student write to Grades if the cell only contains R?

1. Find Student row and Grades column.

2. The entry contains R only.

3. Requested permission is W (Write), which is absent.

Answer: {answer}

{explainer}

How an Access Matrix becomes ACLs and Capabilities

Access Control List (ACL)	Capability List / Ticket
Object-centric: Who can access File A?	Holder-centric: Which objects can User B access?
For Grades: Student=R(own), Lecturer=R/W(assigned)	For Lecturer: Grades=R/W(assigned), Course Notes=R/W
Efficient audit of access to one resource	Efficient identification of rights available to one holder

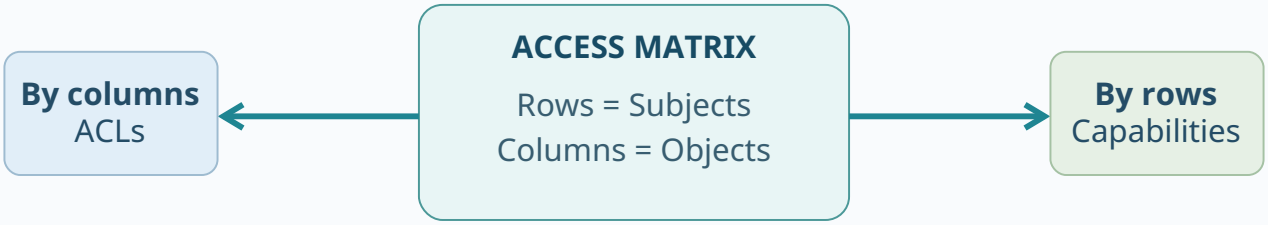


Figure 9.2 – Access Matrix decomposition into object-associated ACLs and holder-associated capabilities.

Why capabilities must be protected

A capability must be **unforgeable**. In a distributed system, cryptographic tokens may represent authorization. Bearer tokens must be protected from theft or misuse.

9.4 RBAC matrices and the Eight Access Control Requirements

RBAC වලදී User → Role → Permission path එක enforce කරනවා. User එකකට roles කිහිපයක් තිබිය හැකි අතර Role එකක් users කිහිපදෙනෙකුට assign කරන්න පුළුවන්. Role එකේ permissions වැරදියට පුළුල් කළොත් Least Privilege violate වෙනවා.



Figure 9.3 – RBAC: Permissions are attached to roles, which are assigned to users.

Requirement	Exam meaning	Example
Reliable Input	Trustworthy identity and policy attributes	Verified user identity
Fine/Coarse-Grained	Field/record-level vs broad table/ system rights	Own results vs whole table
Least Privilege	Minimum necessary permissions	Student can read own marks
Separation of Duty	Different people perform separate critical steps	Initiate vs approve payment
Open vs Closed Policies	Default allow vs default deny	Sensitive system defaults deny
Conflict Resolution	Rule for contradictory policies	Deny-overrides
Administrative Policies	Who may change authorization rules	Only admin can assign roles

Requirement	Exam meaning	Example
Dual Control	Two or more authorized people act jointly	Two signatories for transfer

WORKED EXAMPLE · two related terms

One clerk creates an invoice; a different clerk approves it. A transfer over Rs. 1 million requires two joint approvals. Identify both concepts.

1. Creation and approval are separate tasks.

2. Two people must jointly approve the high-value operation.

Answer: {answer}

{explainer}

9.5 Exam checkpoint – Week 9

Q1. Name the best model when a document owner shares a file.

> **Answer:** DAC

Q2. Name the best model for classified military records.

> **Answer:** MAC (Mandatory Access Control)

Q3. What is the direction of an ACL in an Access Matrix?

> **Answer:** Column/object-centric

Q4. Which principle limits permissions to the minimum needed?

> **Answer:** Least Privilege

Q5. Why can a Capability Ticket be risky?

> **Answer:** Possession may convey authority; tickets must be unforgeable and protected.

සිංහලෙන් මතක තබාගන්න

Week 9 අන්තිමට Access Matrix එකක් ඔබම draw කරන්න. Role එකක් දුන්නම permission matrix එකට ඒක map කරන්න. University හෝ Bank scenario එකක් ආවොත් DAC / MAC / RBAC වෙනස්කම් reason එකක් සමඟ ලියන්න.

WEEK 10

User Authentication

කෙනෙකුගේ claimed identity එක සැබෑද කියලා system එක verify කරන්නේ කොහොමද?

Lecture source: Week 10 – User Authentication, slides 3–25; User Authentication Tutorial.

10.1 Identification, Verification and Authorization

Login process එකේ මුලින් Username/Student ID එකක් දෙනවා. එය Identification. Password, token හෝ biometric proof check කිරීම Verification. Login success වුණාට පස්සේ requested resource එක access කරන්න අවසර තියෙනවද බලන්නේ Authorization. මෙම terms තුන පැටලෙන්න එපා.

> EXAM DEFINITION
>
> **Authentication is the process of verifying an identity claimed by or for a system entity. Identification presents the identifier, and Verification corroborates the identity binding (RFC 2828 definition as quoted in the lecture).**

WORKED EXAMPLE · single scenario

A student enters a username and password. Login succeeds, but opening the lecturer-only grade editor is denied. Classify the steps.

1. Username identifies the account.
2. Password verifies the claimed identity.
3. Grade editor access depends on permissions.

Answer: {answer}

{explainer}

10.2 Four Authentication Factors and MFA

Category	Examples	Threat / limitation
Something You Know	Password, PIN, secret answer	Phishing, guessing, sharing
Something You Have	Hardware token, smart card, registered authenticator	Loss, theft, token compromise
Something You Are	Fingerprint, face, retina	Spoofing and privacy issues
Something You Do	Typing rhythm, handwriting dynamics, voice pattern	Variation and matching errors

MFA vs Two passwords

MFA (Multifactor Authentication) සඳහා different factor categories අවශ්‍යයි. Password + PIN දෙකම Something You Know category එකේ නිසා එය independent-factor MFA නෙවෙයි. Password + authenticator token වගේ combination එක සුදුසුයි.

Password + PIN

Knowledge + knowledge = NOT necessarily MFA

Password + token

Knowledge + possession = MFA

Password + fingerprint

Knowledge + biometric = MFA

SSO + MFA

One central identity service can also require multiple factors

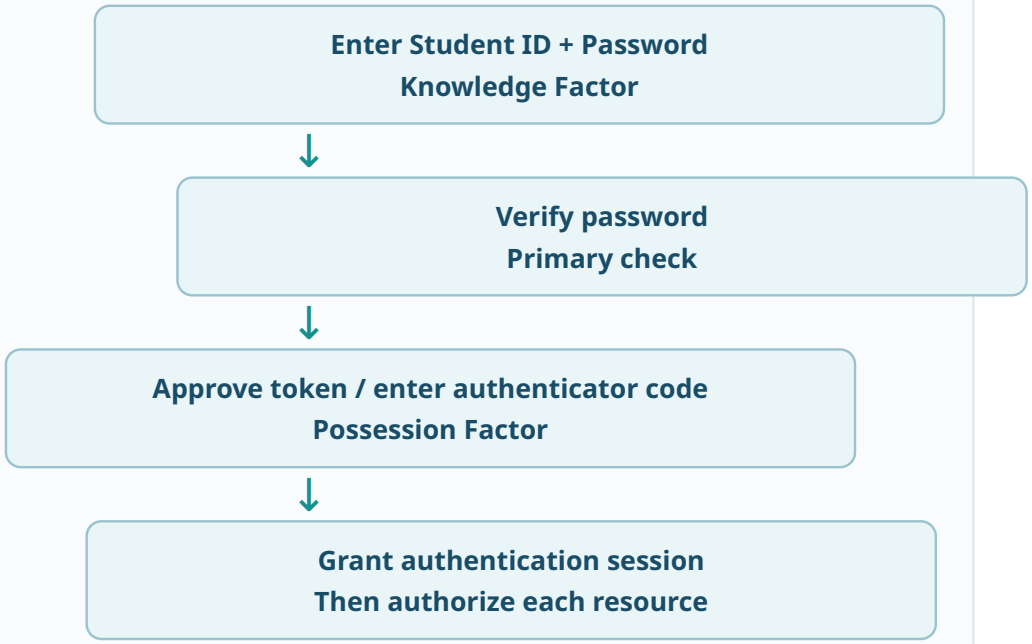


Figure 10.1 – Example of two-factor Courseweb login.

WORKED EXAMPLE · factor trap

A portal asks for a password and then requests a second secret PIN. Is this definitely MFA?

1. Classify password: Knowledge.

2. Classify PIN: Knowledge.

3. Both belong to the same factor category.

Answer: {answer}

{explainer}

10.3 Password Attacks: recognize the scenario

Password questions බොහෝ වෙලාවට Attack Name + Explanation + Countermeasure ලෙස එනවා. Lecture එකේ categories අට සම්පූර්ණයෙන් දැනගන්න. ප්‍රහාරයකදී online login page එකට guesses යවනවද, නැත්නම් stolen password hashes offline test කරනවද කියලා විශේෂයෙන් පරීක්ෂා කරන්න.

Attack	How it appears in a scenario	Suitable response
Offline Dictionary	Stolen hashes tested without live login	Slow salted hashing, protect verifiers
Specific Account	Repeated guesses against one account	Rate limits, temporary lockout
Popular Password	Common password sprayed across many users	Breached-password screening, monitoring, MFA
Single-User Guessing	Uses personal facts to predict password	Unique unpredictable password
Exploiting User Mistakes	Phishing, sharing, exposed passwords	Awareness training, phishing-resistant MFA
Workstation Hijacking	Unattended logged-in device used by outsider	Auto lock, session timeout
Multiple Password Use	Same secret used across services	Unique passwords/password manager
Electronic Monitoring	Authentication data intercepted in transit	Authenticated encrypted connection, secure protocols

Online versus Offline

Online: Attacker submits guesses to the service; rate limiting helps. **Offline:** Attacker tests stolen verifiers; login rate limiting cannot stop those local guesses.

WORKED EXAMPLE · attack classification

An attacker obtains the stolen password database and runs a wordlist locally against the hashes. Which attack, and which controls?

1. No attempts are being sent to the live login service.

2. Candidates are compared to stolen password verifiers.

Answer: {answer}

{explainer}

10.4 Salted password hashing and secure verification

Password database එකක plaintext passwords නොතබා **Password Verifier** store කරනවා. Lecture එකේ Password + Salt → Slow Hash Function → Stored verifier ලෙස පෙන්වනවා. Salt එක user එකකට unique random value එකක් වන අතර secret විය යුතු නැහැ.

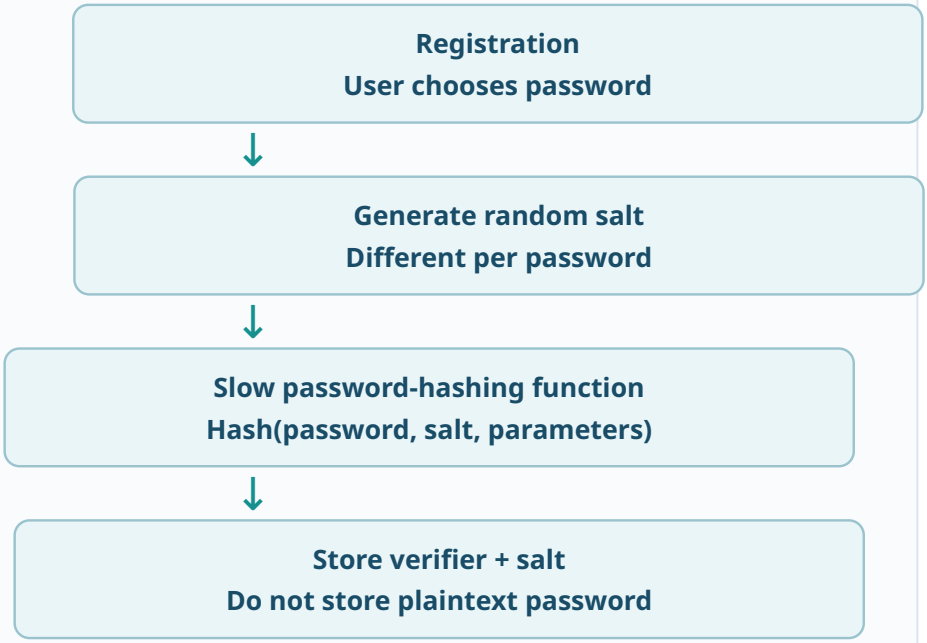


Figure 10.2 – Registration: salted, slow password-verifier storage.

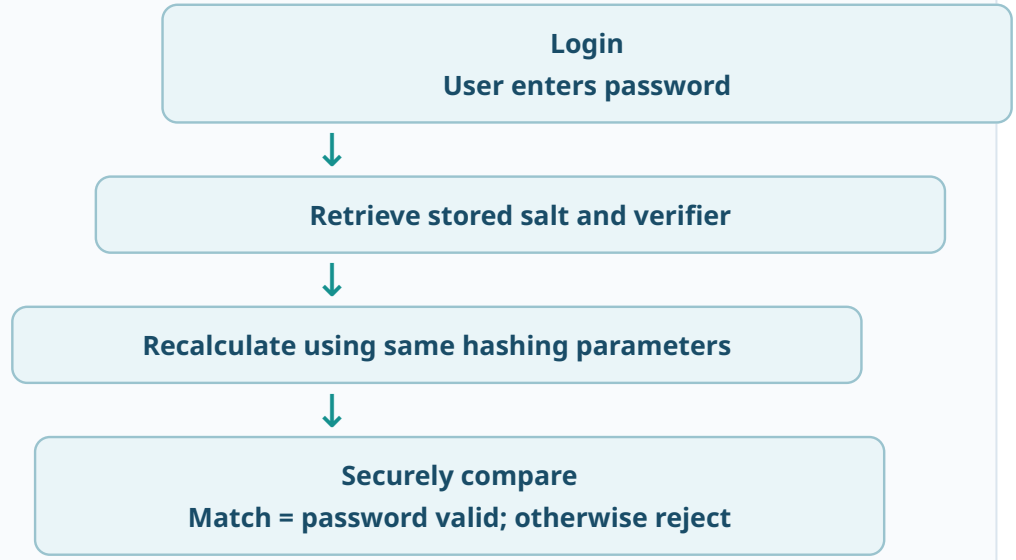


Figure 10.3 – Password verification without storing plaintext passwords.

Why use a salt?	Explanation
Different verifiers	Two accounts sharing a password get different stored verifiers if salts differ.
Precomputation resistance	Makes precomputed tables much less reusable between account salts.
Cross-account comparison	Identical passwords cannot be trivially identified by comparing salted verifiers.

Lecture model vs implementation detail

The lecture depicts a slow hash function. Production systems should use a suitable password-hashing algorithm (e.g., Argon2id or appropriately configured alternatives); a plain fast SHA-256 hash is not a sufficient password-storage default. The salt is generally stored alongside the verifier.

WORKED EXAMPLE · password storage

Two employees choose the same password. Why should their stored password verifiers differ?

1. Generate independent random salts S1 and S2.

2. Compute independent verifiers H(password,S1) and H(password,S2).

Answer: {answer}

{explainer}

10.5 Single Sign-On (SSO): convenience and concentration of risk

University එකේ Courseweb, Library සහ Student Portal තුනකට වෙනම credentials නැතුව central identity provider එකකින් authenticate වීම SSO. User convenience සහ centralized administration ලැබෙනවා. නමුත් identity provider එක unavailable හෝ compromised වුණොත් connected applications කිහිපයකටම impact විය හැකියි.

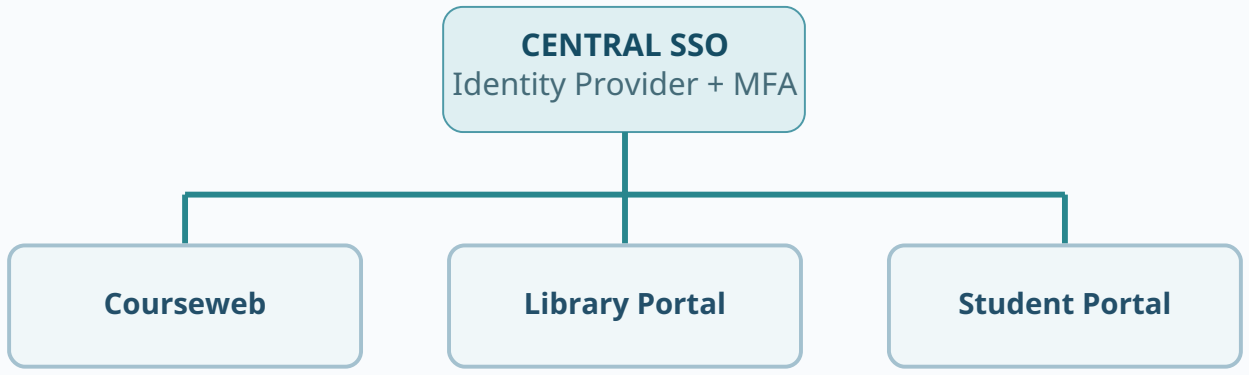


Figure 10.4 – SSO: one central authentication can support access across multiple applications.

SSO advantage	SSO limitation
Reduced credential burden	Identity-provider compromise may affect many applications
Central account administration	Integration complexity and implementation cost
Less repetitive login	Centralized service outage can block sign-ins

10.6 Challenge–Response, Nonce and Replay Protection

Remote Authentication එකේදී attacker කෙනෙකුට previously valid response එකක් capture කරලා later resend කරන්න පුළුවන්. එය Replay Attack. Challenge–Response mechanism එකක් fresh **Nonce (Number used once)** එකක් භාවිත කරලා මේ ගැටලුව අවම කරනවා.

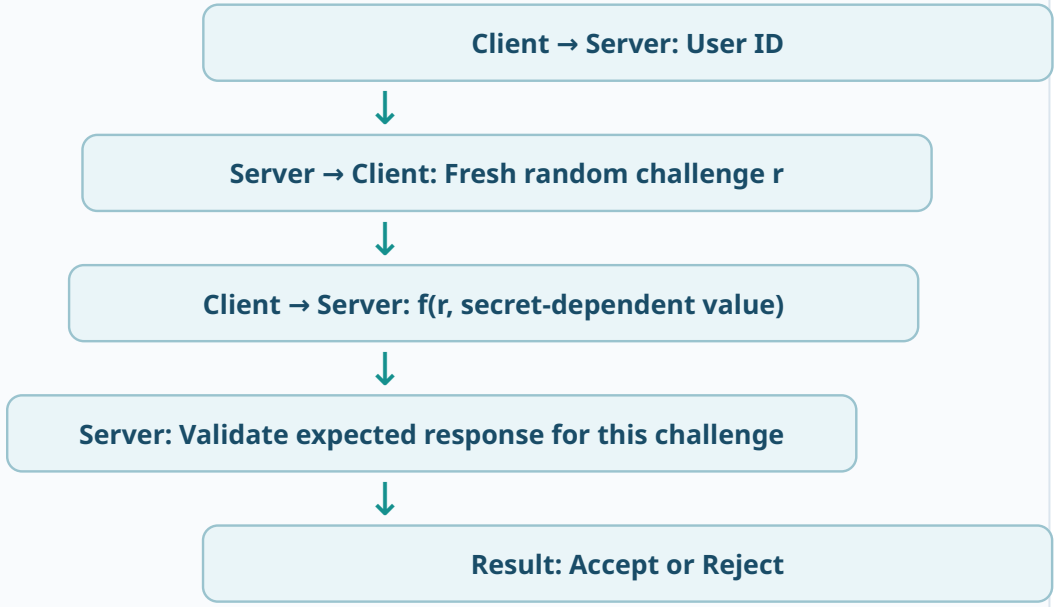


Figure 10.5 – Freshness makes a previously recorded response unsuitable for a new challenge.

Protocol security note

The lecture uses an illustrative formula **R = f(r, h(P))** with a password-derived verifier. A real protocol must be vetted; an insecure construction may expose password-equivalent material or permit offline guessing. Freshness alone does not guarantee resistance to every attack.

WORKED EXAMPLE · replay

A valid response from yesterday is retransmitted today, but the server uses a different random nonce. Why should the attack fail?

1. Yesterday's response was bound to yesterday's nonce.

2. Today's verifier expects a response based on today's challenge.

Answer: {answer}

{explainer}

10.7 Exam checkpoint – Week 10

Q1. Why is password + PIN not automatically MFA?

> **Answer:** Both are knowledge factors.

Q2. Which attack uses stolen password hashes offline?

> **Answer:** Offline Dictionary Attack.

Q3. What is the chief advantage of SSO?

> **Answer:** One central authentication for associated applications.

Q4. Why use a salt?

> **Answer:** Reduce hash equality and precomputation attacks.

Q5. Which threat is addressed by a fresh nonce?

> **Answer:** Replay Attack.

සිංහලෙන් මතක තබාගන්න

Week 10 අනිවාර්ය diagrams දෙක: Salted Hashing process සහ Challenge–Response sequence. English වලින් Step 1 → Step 2 → Step 3 වගේ ලියන්න. MFA scenario එකක factor categories දෙකම සඳහන් කරන්න.

WEEK 11

Disaster Recovery & Business Continuity

Disaster එකක් අතරතුර critical services පවත්වාගෙන යන්නේ සහ damaged systems restore කරන්නේ කොහොමද?

Lecture source: Week 11 – DRP & BCP for Risk Management, slides 3–20; DRP & BCP Tutorial.

11.1 Availability and the difference between DRP and BCP

University Courseweb database එක fire එකකින් fail වුණා කියලා හිතන්න. **DRP** මඟින් primary/backup infrastructure restore කරනවා. **BCP** මඟින් disaster එක අතරතුර assignments, essential resources වැනි critical operations alternate method එකකින් continue කරනවා. මෙය CIA Triad එකේ **Availability** objective එකට සෘජුව සම්බන්ධයි.

Disaster Recovery Planning (DRP)	Business Continuity Planning (BCP)
Restore failed systems, data and infrastructure	Maintain essential business services during disruption
Technology and operations recovery emphasis	Organization-wide essential processes and people
Example: Restore damaged database	Example: Operate alternate admissions portal

WORKED EXAMPLE · identify recovery

A bank activates a backup processing site at noon and rebuilds its damaged main database that evening. Separate BC and DR activities.

1. Temporary processing at backup site maintains service.

2. Rebuilding damaged primary database restores normal infrastructure.

Answer: {answer}

{explainer}

11.2 Recovery timeline, Interruption Window, Alternate Mode, SDO, MTO

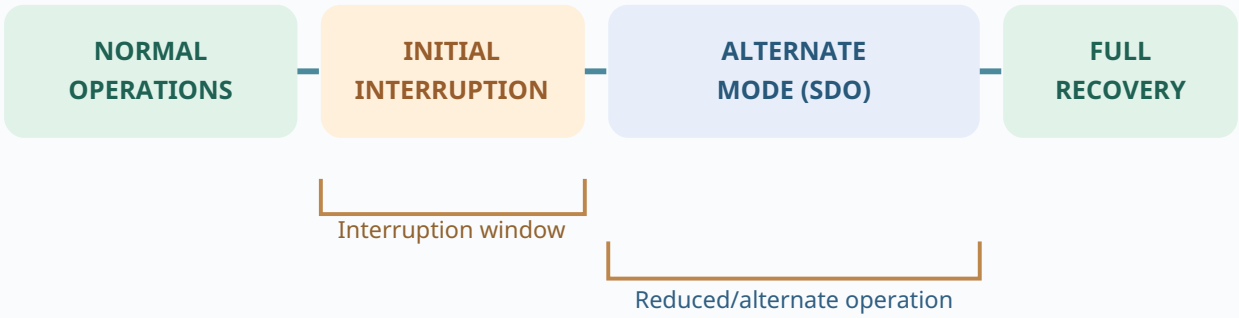


Figure 11.1 – Conceptual recovery timeline based on the lecture.

Term	Lecture-aligned meaning	Example
Interruption Window	Time the organization can wait before a service resumes	1 hour before alternate processing starts
Alternate Mode	Temporary essential operations	Basic online banking functions at a backup site
Service Delivery Objective (SDO)	Target level of service while in alternate mode	Essential transfers and balance viewing
Maximum Tolerable Outage (MTO)	Maximum tolerable disruption/ alternate-mode duration in the lecture	Limit by which recovery must be achieved

Terminology caution

Slide 6 describes MTO as “Maximum time in Alternate Mode”; its timeline bracket spans the disruption-to-restoration period. Learn the source terminology and explain the context. Outside the uploaded lecture, **RTO** (time-to-recover target) and **RPO** (tolerable data loss measured in time) are commonly used, but are **supplementary knowledge**.

WORKED EXAMPLE · timeline calculation

A university system fails at 08:00. Essential alternate services resume at 09:30, and the normal system is restored at 15:00. Find the initial interruption and alternate duration.

1. 08:00 → 09:30 = 1 hour 30 minutes.

2. 09:30 → 15:00 = 5 hours 30 minutes.

Answer: {answer}

{explainer}

11.3 Recovery strategies: Cold, Warm, Hot and Mirrored

Recovery Solution එක තෝරනකොට main trade-off එක **Implementation Cost vs Recovery Time**. Very fast recovery ඛොහෝ විට expensive; Cold Site cheaper නමුත් slower. Lecture එකේ Mutual Backup සහ Remote Journaling ද ඇත.

Approach	What is ready?	Typical time/cost trade-off
Cold Site	Facility + basic infrastructure; equipment setup needed	Slow recovery / lower cost
Warm Site	Some equipment/configuration installed	Moderate time / moderate cost
Hot Site	Ready hardware, software, network	Fast recovery / higher cost
Mirrored Site	Closely duplicated infrastructure and replicated data	Very fast / very high cost
Mutual Backup	Another compatible organization provides facilities	Depends on partner readiness
Remote Journaling	Transaction/data updates transmitted remotely	Depends on architecture and frequency

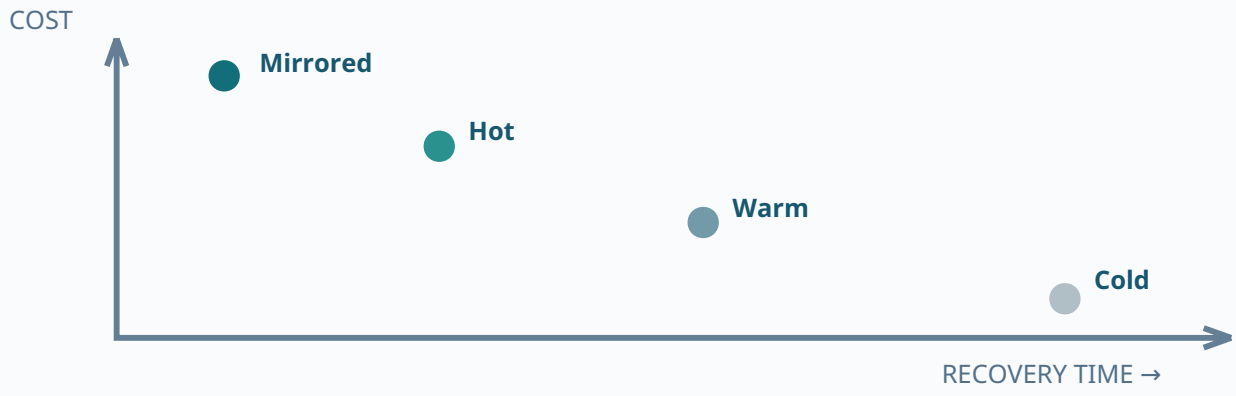


Figure 11.2 – Illustrative cost/recovery-time trend (not measured cost data).

WORKED EXAMPLE · choose the site

An online hospital records system has very low acceptable downtime and a substantial recovery budget. Which site approach may fit best?

1. Identify critical service and extremely low downtime tolerance.

2. Compare high-readiness options with available budget.

3. Choose a site with rapid failover/replication.

Answer: {answer}

{explainer}

11.4 High availability, redundancy and the broader disaster plan

Technology	Purpose	What it does NOT replace
RAID	Local disk redundancy	Off-site backup / full DR
Fault-Tolerant Server	Backup server assumes service after failure	Site-level resilience by itself
Distributed Processing	Spread workload across several nodes	Cross-site recovery without design
Storage Area Network (SAN)	Shared networked storage and data movement	Backup policy and restoration testing

Roles and planning responsibilities

BCP එක IT team එකේ විතරක් responsibility එකක් නෙවෙයි. Executives, managers, business departments සහ employees සහභාගී විය යුතුයි. **BC/DR Coordinator** plans maintain කරලා periodic reviews, updated plans distribution සහ coordination handle කරනවා.

11.5 Six phases of preparing a Business Continuity Plan



Figure 11.3 – The six BCP phases listed in the uploaded lecture.

BCP document section	Why it belongs in the plan
Life safety / evacuation	People are first priority
Disaster declaration criteria	Specify who activates recovery
Responsibilities and contacts	Avoid confusion during an incident
Recovery procedures	Restore failed systems and data
Alternate-mode procedures	Continue essential services
Resource allocation	Prioritize scarce equipment and people
Off-site plan copies	Remain available when primary site is unavailable

11.6 Choose a third-party recovery provider

Company එක third-party backup center එකක් select කරන විට Floor Space, Redundant Equipment, Redundant Network Capacity, Vendor Support, Budget සහ Skilled Personnel කියන factors evaluate කරන්න ඕනේ. Paper එකක 2 factors දෙන්න කියලා ඇහුවොත් name + reason කෙටිව ලියන්න.

WORKED EXAMPLE · vendor criteria

A company rents a disaster recovery facility but it cannot handle its normal transaction volume during failover. Identify two poorly evaluated factors.

1. The site lacks adequate capacity.

2. The network or infrastructure is insufficient for real workload.

Answer: {answer}

{explainer}

11.7 Exam checkpoint – Week 11

Q1. DR or BC: rebuilding a failed main server?

> **Answer:** DR.

Q2. DR or BC: serving customers from a temporary site?

> **Answer:** BC.

Q3. Which is normally slower: Cold or Hot?

> **Answer:** Cold Site.

Q4. What happens during BCP Testing?

> **Answer:** Run exercises and evaluate results.

Q5. Why does RAID not replace backups?

> **Answer:** RAID does not protect against all deletion, corruption, ransomware, or site loss.

සිංහලෙන් මතක තබාගන්න

Week 11 timeline එක draw කරන්න පුළුවන් වෙන්න. Recovery Strategy table එකෙන් 2 advantages/limitations ඉක්මනින් compare කරන්න. Six BCP Phases අනුපිළිවෙළට English වලින් ලියන්න.

WEEK 12

Firewalls, ACLs & Network Security

Network packets monitor කරලා dangerous traffic නවත්වන්නේ කොහොමද?

Lecture source: Week 12 – Firewalls, ACLs & Network Security, slides 5–36.

12.1 Firewall fundamentals and packet filtering

Firewall එක Protected Network එකක් සහ Untrusted Network එකක් අතර **Electronic Checkpoint** එකක් ලෙස වැඩ කරනවා. Basic packet filtering වල Source IP, Destination IP, Source Port, Destination Port සහ TCP/UDP Protocol අනුව traffic Allow/Deny කරනවා.

EXAM DEFINITION

A Firewall is a hardware or software security system that controls traffic into or out of a protected network according to defined security rules.

Layer 3

Source and Destination IP addresses

Layer 4

TCP/UDP ports and transport protocol

Application Layer

Application-protocol behavior and content

Secondary services

NAT, VPN tunnelling and proxy service

Typical service	Port / protocol	Lecture relevance
HTTP	TCP 80	Public web site and client requests
SMTP	TCP 25	Email delivery in lecture example
SSH	TCP 22	Supplementary management access example
HTTPS	TCP 443	Supplementary encrypted web example

Access Control Lists (ACLs)

Network ACL එකක් ordered traffic rules list එකක්. Lecture example එකේ rules **Top-to-Bottom / First Match** evaluate කරනවා. Interface-specific IN/OUT direction එකක් තිබෙන නිසා packet direction carefully බලන්න. No match නම් implicit/explicit Default Deny යොදාගන්නවා.

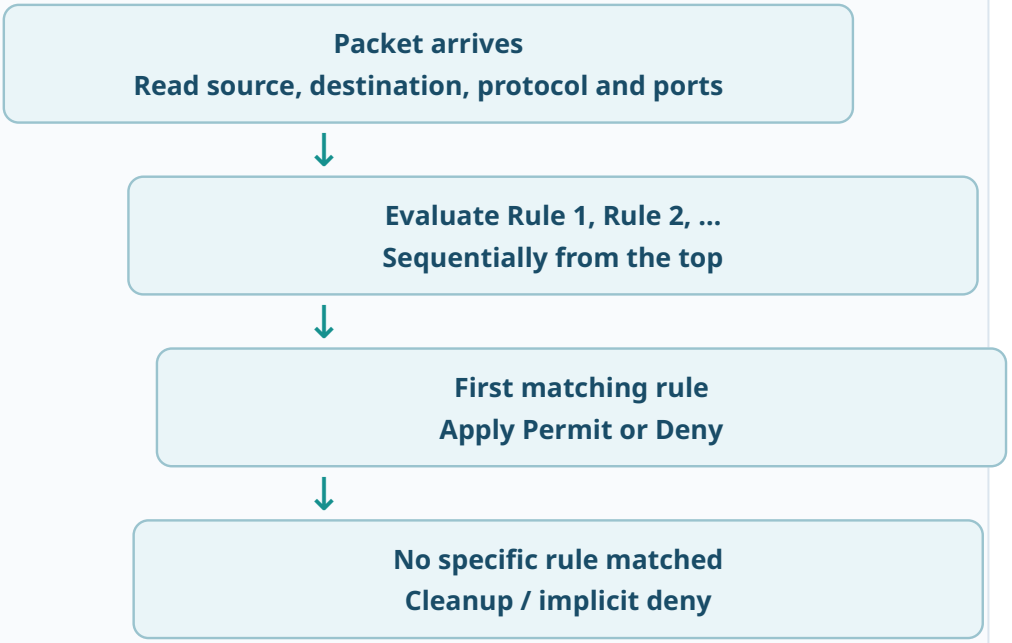


Figure 12.1 – Ordered ACL processing in the lecture.

Two must-know rules

Stealth Rule: Blocks unauthorized traffic to the firewall itself (usually near the beginning). **Cleanup Rule:** Denies all otherwise unmatched traffic (usually final rule).

12.2 The lecture firewall case study: all A–I rules

Firewall protects **10.1.0.0/16**. Internal devices may access external HTTP sites except host **10.2.12.12**. External users may reach Email Server **10.1.1.2** on TCP 25 and Web Server **10.1.0.20** on TCP 80. Traffic to the firewall itself (**10.1.0.1**) is denied. Other traffic is denied.

Rule	Source	S.Port	Destination	D.Port	Proto	Action
A	Any	Any	10.1.0.1	Any	Any	Deny
B	10.1.0.0/16	Any	10.2.12.12	Any	Any	Deny
C	10.1.0.0/16	Any	Any	80	TCP	Allow
D	Any	80	10.1.0.0/16	Any	TCP	Allow
E	Any	Any	10.1.1.2	25	TCP	Allow
F	10.1.1.2	25	Any	Any	TCP	Allow
G	Any	Any	10.1.0.20	80	TCP	Allow
H	10.1.0.20	80	Any	Any	TCP	Allow
I	Any	Any	Any	Any	Any	Deny

Source fidelity

The table is a cleaned transcription of the lecture rule pattern. The notation 10.1.0.0/16 clarifies that 10.1.0.0 refers to the protected subnet; “Any” corresponds to the lecture wildcard (*). Rule matching is first-match top-to-bottom.

WORKED EXAMPLE · specific deny precedes general allow

Internal host 10.1.0.3 attempts HTTP to blocked host 10.2.12.12. Which rule matches first?

1. A? Destination is not firewall 10.1.0.1, so no.

2. B? Source belongs to internal subnet and destination is 10.2.12.12, so yes.

3. Stop: later HTTP Allow C is not evaluated.

Answer: {answer}

{explainer}

WORKED EXAMPLE · return traffic

A reply packet travels from 198.51.100.8:80 to 10.1.0.3:50000 using TCP. Which stateless lecture rule matches?

1. Not addressed to firewall; not blocked host.

2. Not internal-origin HTTP request (C).

3. Source port is 80; destination is internal subnet.

Answer: {answer}

{explainer}

WORKED EXAMPLE · cleanup

A host 203.0.113.8 attempts TCP 22 to 10.1.0.5. Which rule handles it?

1. No special allow rule matches SSH to that internal host.

2. Reach final catch-all deny.

Answer: {answer}

{explainer}

12.3 Stateless versus Stateful Packet Inspection

Stateless Filtering	Stateful Inspection
Independent packet rules	Uses connection/session state
Return traffic may need explicit broad ACL rule	Related return traffic is recognized by state

Stateless Filtering	Stateful Inspection
Limited association with genuine sessions	More context for permitting incoming responses
Simpler but can be difficult with dynamic ports	Tracks legitimate TCP connection setup

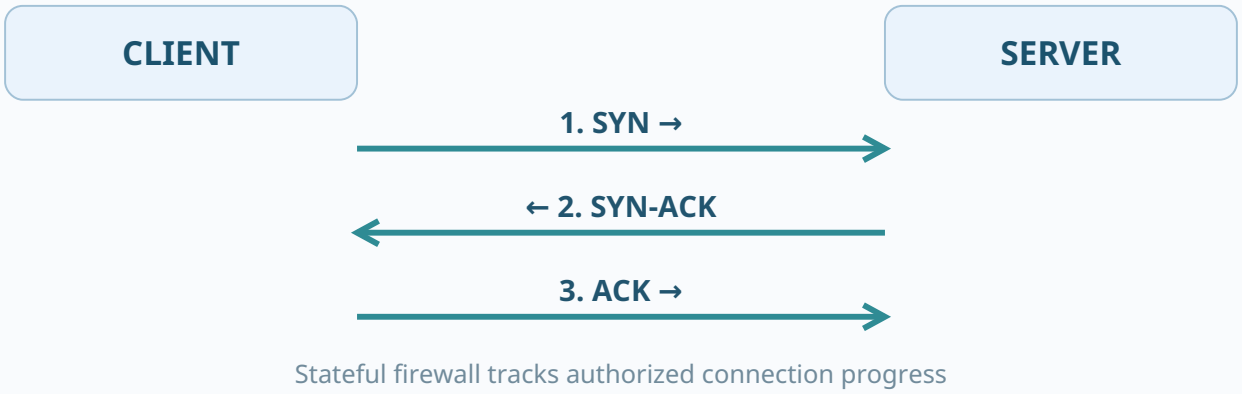


Figure 12.2 – Simplified TCP three-way handshake.

Practical clarification

The lecture's stateless return rule allows any TCP packet with source port 80 towards the internal subnet; source port alone cannot prove that a packet is a legitimate response. Stateful inspection checks whether the packet is consistent with tracked authorized sessions.

12.4 Firewall architectures and the DMZ

Simple Topology: Filtering Router → Internal LAN. **Screened Host:** Filtering Router + Bastion Host. **DMZ (Demilitarized Zone):** Public Web/Email services placed in a distinct screened subnet between Internet and sensitive internal network. මෙයින් Public Servers compromise වුණත් Internal Database වලට direct unrestricted access අඩු කළ හැකියි.

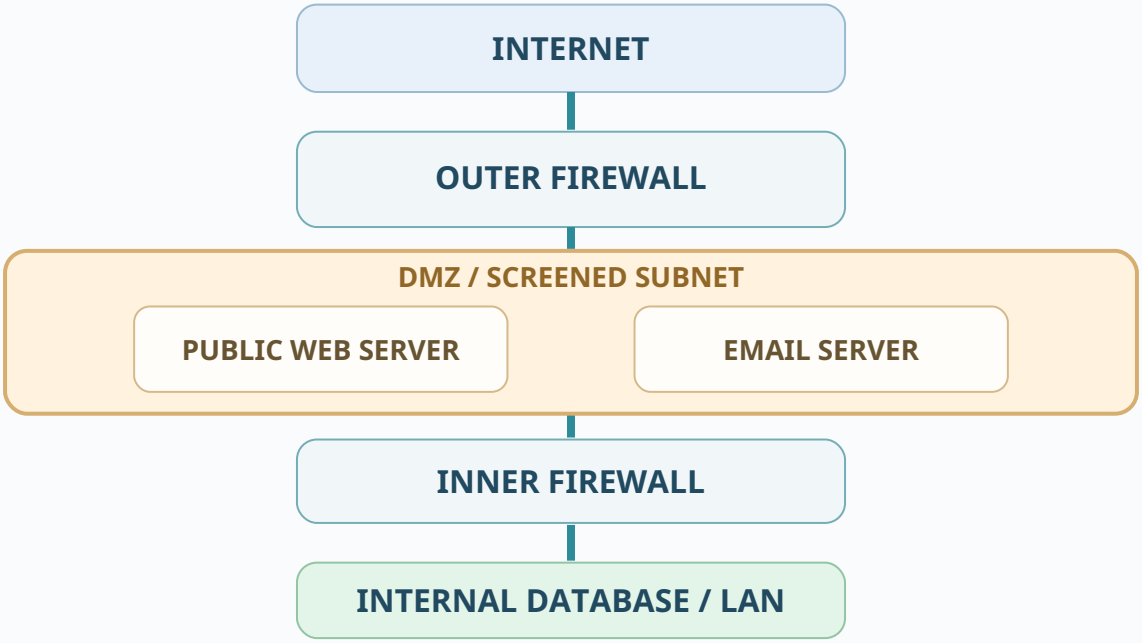


Figure 12.3 – A two-firewall screened-subnet DMZ inspired by Lecture Slides 26–28.

WORKED EXAMPLE · DMZ decision

A hospital runs an externally accessible appointment website and a confidential patient database. Where should the public website be placed?

1. Website requires external access.

2. Clinical database must remain in protected internal network.

3. Place the public service in isolated DMZ and restrict DMZ-to-database traffic.

Answer: {answer}

{explainer}

12.5 UTM, SIEM, IDS and IPS

Technology	What it does	Scenario clue
UTM	Integrates firewall, anti-malware, filtering, IDS functions	One appliance / integrated controls
SIEM	Collects and correlates firewall, server, application logs	Central alerts and log analysis
IDS	Detects suspicious activity and alerts	Observe / generate alarm
IPS	Detects and can stop malicious traffic	Block / terminate connection

How does IDS decide something is suspicious?

Signature-Based	Anomaly-Based
Compare with known malicious signatures	Detect deviations from learned/defined normal behavior
Effective for recognized patterns	Can find unusual or novel behavior
Needs signature updates	May cause false alarms when normal behavior changes

True Positive, False Positive, True Negative, False Negative

Actual \ Predicted	Alarm	No alarm
Actual attack	True Positive (TP)	False Negative (FN)
Normal activity	False Positive (FP)	True Negative (TN)

WORKED EXAMPLE · false positive

The IDS raises an intrusion alert for a legitimate student downloading lecture slides. What is this?

1. Actual condition is normal.

2. IDS decision is an alarm.

Answer: {answer}

{explainer}

12.6 VPN and tunnelling

VPN එක Public Internet හරහා protected logical tunnel එකක් create කරනවා. **Tunnelling** කියන්නේ original packets outer protocol එකක් තුළ encapsulate කරලා transport කිරීම. VPN protection endpoints අතරට පමණක් විය හැකි නිසා application-level security තවදුරටත් වැදගත්.

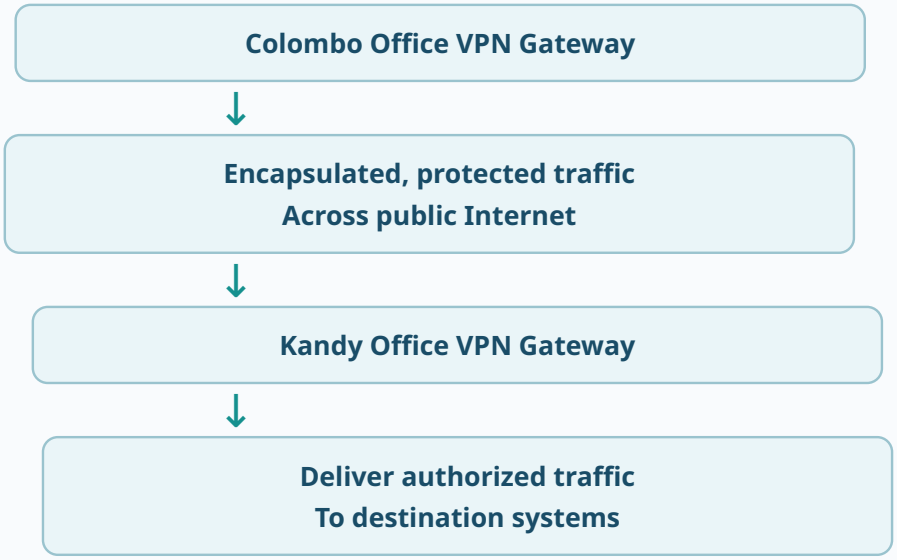


Figure 12.4 – Site-to-site VPN concept.

VPN benefit	VPN limitation
Protects traffic across shared networks	Additional processing and encapsulation overhead
Supports site-to-site and remote access	Tunnel protection may end at VPN gateway
Can help protect traffic confidentiality and integrity	Does not by itself fix compromised endpoints

12.7 Exam checkpoint – Week 12

Q1. Which rule denies traffic to the firewall itself?

> **Answer:** Stealth Rule.

Q2. Which rule denies all otherwise unmatched traffic?

> **Answer:** Cleanup Rule.

Q3. HTTP and SMTP ports in the lecture?

> **Answer:** HTTP TCP 80; SMTP TCP 25.

Q4. Which technology tracks active connections?

> **Answer:** Stateful Packet Inspection.

Q5. What is a False Negative?

> **Answer:** An actual attack that the IDS fails to detect.

සිංහලෙන් මතක තබාගන්න

Week 12 සඳහා ACL table එක blank paper එකක draw කරලා packets 5ක් check කරන්න. Source/Destination, TCP Port සහ first-match rule order වැරදෙන්න ඉඩ තියෙන නිසා අනිවාර්යයෙන්ම step-by-step check කරන්න.

EXAM TECHNIQUE • PAST PAPER PRACTICE

Past-Paper-Adapted Question Clinic

පරණ papers වල pattern එකෙන් අලුත් scenarios solve කරන ආකාරය

These are **adapted / paraphrased** from the older uploaded IT3070 papers, not presented as verbatim official questions. Each example is chosen to represent a recurring task type. The model answers are newly written.

WORKED EXAMPLE · 2024 paper, Q3(c): Access Matrix

At a university, U1 (Professor) may Read all resources. U2 (Graduate Student) may Read Course Materials and Department Email. U3 (Staff) may Read Course Materials and Write Research Datasets. U4 (Guest) has no access. Build an access matrix.

1. Create rows U1 to U4 and columns R1 Course Materials, R2 Research, R3 Email, R4 Lab Computers.

2. Enter only explicitly permitted rights.

3. Use "—" for denied/unspecified rights.

Answer: {answer}

{explainer}

User	R1 Course	R2 Research	R3 Email	R4 Lab
U1 Professor	R	R	R	R
U2 Graduate	R	—	R	—
U3 Staff	R	W	—	—
U4 Guest	—	—	—	—

WORKED EXAMPLE · 2024 paper, Q3(d): Choose the model

Select DAC, MAC, or RBAC for: (a) hospital job duties; (b) classified government laboratory; (c) collaborative document with owner-managed sharing.

1. Hospital decisions depend on job roles.

2. Classified laboratory depends on security labels and clearances.

3. Shared document owner can grant editing or viewing.

Answer: {answer}

{explainer}

WORKED EXAMPLE · Older paper, Q3(d): SSO proposal

A university wants one login for the LMS, library, computer labs and help desk. Give two benefits, two risks, and explain why MFA matters.

1. SSO reduces repeated sign-in burden and simplifies administration.

2. Centralized service outage and account compromise may affect multiple applications.

3. MFA reduces reliance on a single compromised password.

Answer: {answer}

{explainer}

WORKED EXAMPLE · 2022 paper, Q4(a): authentication protocol

Explain a challenge-response authentication sequence that uses a fresh nonce to defend against replay.

1. Client identifies the account.

2. Server issues a fresh random nonce.

3. Client computes response using the challenge and authentication secret.

4. Server verifies the response before authorizing an authenticated session.

Answer: {answer}

{explainer}

WORKED EXAMPLE · 2024 paper, Q4(b): salts

State two benefits of unique random salts when storing hashed passwords.

1. Different salts make identical passwords produce different verifiers.

2. Salts reduce reuse of precomputed hash tables.

Answer: {answer}

{explainer}

WORKED EXAMPLE · 2022 paper, Q4(b): firewall rule position

A firewall needs a rule restricting direct traffic to its own management address. Name the rule and state where it usually appears.

1. Identify the object requiring protection: firewall itself.

2. The rule should be evaluated before broad general permits.

Answer: {answer}

{explainer}

WORKED EXAMPLE · 2024 paper, Q4(c): new firewall scenario

Protect subnet 192.168.10.0/24. Block internal HTTP requests to 100.23.13.11; allow other outgoing TCP 80; allow external HTTP to public web server 192.168.10.123; deny remaining traffic. Construct core stateless ACL rules.

1. Deny specifically blocked external destination first.

2. Allow internal TCP destination port 80.

3. Provide matching return-traffic rule for stateless model.

4. Allow incoming HTTP to the web server and its response traffic.

5. Finish with default deny.

Answer: {answer}

{explainer}

Order	Source	S.Port	Destination	D.Port	Protocol	Action
1	192.168.10.0/24	Any	100.23.13.11	Any	Any	Deny
2	192.168.10.0/24	Any	Any	80	TCP	Allow
3	Any	80	192.168.10.0/24	Any	TCP	Allow
4	Any	Any	192.168.10.123	80	TCP	Allow
5	192.168.10.123	80	Any	Any	TCP	Allow
6	Any	Any	Any	Any	Any	Deny

Firewall solution caveat

The table follows the source lecture's simplified stateless rule approach. It is not a complete production-grade firewall policy: rule direction, anti-spoofing, stateful controls, approved management rules and interfaces must be evaluated in a real deployment.

WORKED EXAMPLE · Older paper, Q4(e): site selection

A medium-sized company has severe budget limitations and chooses a Cold Site with backups. Explain Cold Site and suggest two alternatives.

1. Cold Site offers a facility and basic infrastructure but needs equipment/setup after disruption.

2. Other site strategies vary in readiness and cost.

Answer: {answer}

{explainer}

WORKED EXAMPLE · 2024 paper, Q4(d): DR provider

Name two factors to evaluate before contracting a third-party DR provider and explain why.

1. Choose practical capacity factor.

2. Choose expertise/support factor.

Answer: {answer}

{explainer}

How to score well in these questions

For 3–4 mark scenarios, write **the named concept**, **one defining characteristic**, and **the reason it matches the facts**. For an Access Matrix or ACL, explicitly show the table and then briefly justify crucial allow/deny decisions.

NEW FORMAT • COMPLETE PRACTICE PAPER

100-Mark Mock Examination

සති 09–12 සඳහා අලුතින් සකස් කළ 49-question practice paper

Mock instructions

This is a **topic-focused practice paper** for Weeks 9–12, not an official prediction. **Part 1 = 35 × 1 = 35 marks; Part 2 = ten 4-mark questions + one 3-mark question = 43; Part 3 = 7 + 7 + 8 = 22.** All questions compulsory; no calculator. **Attempt before moving to the answer section.**

PART 1 • 35 Questions • 35 Marks

Q01. Which term identifies an entity that requests access to a protected object? [1 mark • MCQ]

A. Firewall
B. Subject
C. Salt
D. Certificate

Q02. A doctor receives permissions through the Doctor role. Which policy is used? [1 mark • MCQ]

A. DAC
B. MAC
C. RBAC
D. Default Allow

Q03. A government research lab assigns security classification labels and clearances. Choose the model. [1 mark • MCQ]

A. MAC
B. DAC
C. Password Policy
D. ACL only

Q04. A file owner allows another user to edit a document. Which is the best model? [1 mark • MCQ]

A. RBAC
B. DAC
C. IDS
D. Mandatory clearance

Q05. Which representation tells you who can read a particular file? [1 mark • MCQ]

A. A file ACL

B. A user password

C. A nonce

D. An RPO

Q06. A user holds an unforgeable reference allowing Write on Object A. This is a: [1 mark • MCQ]

A. Salt

B. Capability

C. Firewall

D. SSO session only

Q07. A user with successful authentication must be permitted to access every resource. [1 mark • True/False]

True

False

Q08. A clerk creates a payment and a different clerk approves it. Identify the principle. [1 mark • MCQ]

A. Dual Control only

B. Separation of Duty

C. Default Allow

D. Replay

Q09. What is the default decision of a Closed Access Control Policy? [1 mark • Short]

Write one short answer.

Q10. A username is entered before a password is checked. Username entry is: [1 mark • MCQ]

A. Authorization

B. Identification

C. Recovery

D. Mirroring

Q11. Which pairing represents different authentication factor categories? [1 mark • MCQ]

A. Password + PIN

B. PIN + Security question

C. Password + Security token

D. Two passwords

Q12. Stolen password hashes are tested without using the login page. Identify the attack. [1 mark • MCQ]

A. Replay
B. Offline Dictionary
C. Workstation Hijacking
D. SYN Flood

Q13. A common password is tested across hundreds of accounts. Which attack fits? [1 mark • MCQ]

A. Popular Password Attack
B. Collision Attack
C. MAC Spoofing
D. Packet Filtering

Q14. Different random salts can make identical passwords produce distinct stored verifiers. [1 mark • True/False]

True
False

Q15. What helps limit replay of captured challenge-response credentials? [1 mark • MCQ]

A. Reused nonce
B. Fresh nonce
C. Longer username
D. Shared browser

Q16. A university uses one central login for Library, LMS and Student Portal. This is: [1 mark • MCQ]

A. RAID
B. SSO
C. DAC
D. UTM

Q17. Name one physical or behavioral biometric from the uploaded lecture. [1 mark • Short]

Write one short answer.

Q18. Workstation hijacking necessarily requires an attacker to know the user's password. [1 mark • True/False]

True
False

Q19. Rebuilding a failed primary database after a disaster is mainly: [1 mark • MCQ]

A. Business Continuity
B. Disaster Recovery
C. Authentication
D. RBAC

Q20. Continuing essential customer operations at a temporary site is mainly: [1 mark • MCQ]

A. BCP
B. Hashing
C. DAC
D. Authentication

Q21. Which site generally has basic facilities but requires more installation before operation? [1 mark • MCQ]

A. Mirrored
B. Hot
C. Cold
D. Fully active dual data center

Q22. An alternate site closely replicates the primary data center for very rapid recovery. This is: [1 mark • MCQ]

A. Cold Site
B. Mirrored Site
C. Mutual Backup
D. Password Vault

Q23. What does SDO mean in the disaster-recovery lecture? [1 mark • Short]

Write one short answer.

Q24. A company exercises its continuity plan in a simulated outage. Which BCP phase? [1 mark • MCQ]

A. Maintenance
B. Testing
C. Project Initiation
D. Design

Q25. RAID alone guarantees full protection against flood and ransomware incidents. [1 mark • True/False]

True
False

Q26. Two compatible companies agree to provide recovery facilities for each other. Identify the approach. [1 mark • MCQ]

A. Remote Journaling
B. Mutual Backup
C. Hashing
D. VPN

Q27. Which firewall rule usually denies unmatched traffic at the end of an ACL? [1 mark • MCQ]

A. Stealth
B. Cleanup
C. Authentication
D. NAT

Q28. Which rule helps prevent unauthorized traffic directed to the firewall itself? [1 mark • MCQ]

A. Stealth Rule
B. Cleanup only
C. Allow All
D. Mirroring

Q29. Which packet attribute identifies TCP web service in the lecture? [1 mark • MCQ]

A. TCP 22
B. TCP 25
C. TCP 80
D. UDP 123

Q30. Which filtering technique maintains information about an authorized TCP session? [1 mark • MCQ]

A. Stateless
B. Stateful Packet Inspection
C. Simple XOR
D. HMAC

Q31. Where should an Internet-facing public server be isolated from a confidential database? [1 mark • MCQ]

A. Only inside database subnet
B. DMZ
C. Password table
D. Certificate store

Q32. An IDS false positive means a real attack occurred but no alarm was raised. [1 mark • True/False]

True
False

Q33. Which system primarily correlates firewall, server, and application security logs? [1 mark • MCQ]

A. SIEM
B. RAID
C. DAC
D. Cold Site

Q34. Which technology can automatically block detected malicious network traffic? [1 mark • MCQ]

A. IDS only

B. IPS

C. Password Salt

D. BCP

Q35. What does VPN stand for? [1 mark • Short]

Write one short answer.

PART 2 • 11 Questions • 43 Marks

Q01. Construct a 3×3 Access Matrix for: Student may Read Own Results and Course Notes; Lecturer may Read/Write Assigned Results and Course Notes; Administrator may Manage Accounts only. Use — for denied rights. [4 marks]

Q02. Explain DAC, MAC and RBAC by selecting the best policy for (a) owner-controlled file sharing, (b) classified defense documents, and (c) hospital job permissions. [4 marks]

Q03. A bank separates payment creation from approval and requires two officers for unusually large transfers. Identify and distinguish the two security requirements. [4 marks]

Q04. Identify four authentication factor categories and give a valid example for each. [4 marks]

Q05. Explain password registration and login verification using a unique random salt and slow password hashing. [4 marks]

Q06. Describe a challenge–response protocol with a nonce and explain the attack it mitigates. [4 marks]

Q07. A service fails at 08:30, starts Alternate Mode at 10:00 and is fully restored at 14:30. Calculate the initial interruption and alternate-mode duration; define SDO. [4 marks]

Q08. Compare Cold, Hot and Mirrored recovery sites using readiness, speed and cost. [4 marks]

Q09. List the six BCP preparation phases in order and explain why Testing and Maintenance are needed. [4 marks]

Q10. Given ACL rules in order: 1 Deny Internal → 203.0.113.50; 2 Allow Internal → TCP 80; 3 Deny Any. Decide (a) Internal HTTP to 203.0.113.50 and (b) Internal HTTP to 198.51.100.8, justifying first match. [4 marks]

Q11. Define DMZ and briefly distinguish IDS from IPS in a public-web-service deployment. [3 marks]

PART 3 • 3 Questions • 22 Marks

Q01. University access & identity (7 marks). A university introduces a single-login portal for students, lecturers and administrators. Students must not edit marks; lecturers can edit assigned-course results; account administrators manage users. Some student passwords have been stolen. Design a suitable access-control and authentication solution. [7 marks]

Q02. Disaster recovery of an online hospital (7 marks). A hospital data center is damaged by flooding. Emergency clinicians need continued access to essential records. The hospital can fund a well-prepared recovery site but wants to prevent recent data loss. Recommend an integrated DRP and BCP strategy. [7 marks]

Q03. Network breach defense and incident handling (8 marks). A company hosts a public website, an email server and an internal payroll database. An external attacker probes internal ports while suspicious traffic appears on multiple systems. Design a network-security architecture and incident-monitoring strategy. [8 marks]

Stop here and attempt the questions.

ඉදිරියේ තියෙන්නේ පිළිතුරු සහ Sinhala explanations. මෙතැනින් ඉදිරියට යන්න කලින් 49 questionsම අවම වශයෙන් වරක් answer කරන්න.

ANSWER BOOKLET • MARKING GUIDE

Mock Examination – Model Answers

පිළිතුරු විතරක් නොව, marks ලැබෙන keywords සහ සිංහලෙන් reasoning

PART 1 • Answer key with explanations

Q01. B — Subject is a user or process requesting access.

Subject කියන්නේ request කරන user/process එක.

Q02. C — RBAC connects roles to permissions.

Job role එක මත permissions.

Q03. A — Mandatory Access Control uses labels/clearances.

Classification + Clearance → MAC.

Q04. B — DAC allows authorized owners discretion over sharing.

Owner discretion → DAC.

Q05. A — Object-associated ACL shows access rights on that file.

File එක සඳහා authorized users list = ACL.

Q06. B — Capability carries specific resource authority.

Unforgeable authority reference = capability.

Q07. False — Authorization separately decides which operations are allowed.

Authentication ≠ Authorization.

Q08. B — Separate people execute separate critical steps.

Responsibilities divide කිරීම = Separation of Duty.

Q09. Deny — Closed Policy denies unless an explicit permission allows access.

Closed = Default Deny.

Q10. B — The identifier is a claim of identity.

Username = Identification.

Q11. C — Knowledge + possession are distinct categories.

Something You Know + Have.

Q12. B — Attacker performs guessing locally on stolen verifiers.

Offline කියන keyword එක බලන්න.

Q13. A — One popular candidate applied to many accounts is password spraying.

Many accounts + common password.

Q14. True — Salt varies the input to the password hashing function.

Same password + different salt = different verifier.

Q15. B — A fresh challenge binds a response to the new exchange.

Fresh Nonce → replay harder.

Q16. B — Single Sign-On uses centralized authentication for associated apps.

One sign-in across apps.

Q17. Fingerprint / Face / Retina / Typing rhythm / Voice pattern / Handwriting — Any relevant static or dynamic biometric example is acceptable.

Something You Are/Do.

Q18. False — An unattended authenticated session may be abused.

Already logged-in session.

Q19. B — DR restores systems; BC maintains operations.

Rebuild = DR.

Q20. A — BCP maintains critical operations during disruption.

Continue = BC.

Q21. C — Cold Sites are less ready and typically recover more slowly.

Cold = cheaper/slower.

Q22. B — Mirrored Sites closely duplicate infrastructure/data.

Mirrored = high readiness.

Q23. Service Delivery Objective — Target service level in Alternate Mode.

SDO = Service Level.

Q24. B — Testing evaluates recovery procedures in a drill.

Simulation → Testing.

Q25. False — Local disk redundancy is not a protected off-site backup.

RAID ≠ DR Backup.

Q26. B — Mutual Backup is a reciprocal facility arrangement.

Partner organizations share backup facilities.

Q27. B — Cleanup Rule implements a catch-all deny.

Final Deny Any.

Q28. A — Stealth Rule restricts access to firewall interfaces.

Protect firewall itself.

Q29. C — HTTP is TCP port 80 in the lecture.

HTTP 80, SMTP 25.

Q30. B — SPI tracks session state.

Session tracking → Stateful.

Q31. B — DMZ separates public-facing services from internal LAN.

Public-facing servers → DMZ.

Q32. False — That is a false negative. False positive is an alarm on legitimate activity.

FP = False Alarm, FN = Missed Attack.

Q33. A — SIEM aggregates and correlates security events.

SIEM = Logs + Correlation.

Q34. B — IPS can take blocking/prevention actions.

IPS → Prevention.

Q35. Virtual Private Network — Protected logical connection over public/shared networks.

VPN = Virtual Private Network.

PART 2 • Structured model answers and marking points

Q01. 4 marks — Construct a 3×3 Access Matrix for: Student may Read Own Results and Course Notes; Lecturer may Read/Write Assigned Results and Course Notes; Administrator may Manage Accounts only. Use — for denied rights.

[1 mark] Define clear subject rows and object columns.

[1 mark] Student: Results R (own), Notes R, Accounts —.

[1 mark] Lecturer: Results R/W (assigned), Notes R/W, Accounts —.

[1 mark] Admin: Results —, Notes —, Accounts Manage.

Exam note: Exam tip: Do not infer permissions not in the prompt.

Q02. 4 marks — Explain DAC, MAC and RBAC by selecting the best policy for (a) owner-controlled file sharing, (b) classified defense documents, and (c) hospital job permissions.

[1 mark] DAC: owner/authorized entity determines sharing permissions.

[1 mark] MAC: security classifications and clearances.

[1 mark] RBAC: permissions linked to organizational roles.

[1 mark] Correct application: (a) DAC, (b) MAC, (c) RBAC.

Exam note: Identify basis + why it matches.

Q03. 4 marks — A bank separates payment creation from approval and requires two officers for unusually large transfers. Identify and distinguish the two security requirements.

[1 mark] Separation of Duty divides payment creation and approval.

[1 mark] SoD reduces conflict of interest and fraud.

[1 mark] Dual Control requires multiple authorized individuals for the high-value transfer.

[1 mark] State the difference: separate steps versus joint participation in a sensitive action.

Exam note: Do not mix SoD and Dual Control.

Q04. 4 marks — Identify four authentication factor categories and give a valid example for each.

[1 mark] Know – Password or PIN.

[1 mark] Have – Smart card/security token.

[1 mark] Are – Fingerprint or face.

[1 mark] Do – Typing rhythm or handwriting behavior.

Exam note: Password + PIN are not two categories.

Q05. 4 marks — Explain password registration and login verification using a unique random salt and slow password hashing.

[1 mark] Registration: generate unique random salt.

[1 mark] Create a verifier using a slow password-hashing function; store verifier + salt, not plaintext.

[1 mark] At login, retrieve salt/parameters and recompute using entered password.

[1 mark] Compare verifiers and accept/reject; salts reduce hash equality/precomputation.

Exam note: Separate registration steps from verification steps.

Q06. 4 marks — Describe a challenge–response protocol with a nonce and explain the attack it mitigates.

[1 mark] Server produces a fresh unpredictable challenge/nonce.

[1 mark] Client derives a response from challenge and authentication secret.

[1 mark] Server verifies the correct response for that challenge.

[1 mark] Recorded responses should fail for new challenges, reducing Replay Attacks.

Exam note: Freshness is the crucial idea.

Q07. 4 marks — A service fails at 08:30, starts Alternate Mode at 10:00 and is fully restored at 14:30. Calculate the initial interruption and alternate-mode duration; define SDO.

[1 mark] Initial interruption: 08:30 to 10:00 = 1 h 30 min.

[1 mark] Alternate Mode: 10:00 to 14:30 = 4 h 30 min.

[1 mark] SDO = Service Delivery Objective.

[1 mark] SDO expresses service level intended during alternate operations.

Exam note: Treat initial interruption and alternate duration separately.

Q08. 4 marks — Compare Cold, Hot and Mirrored recovery sites using readiness, speed and cost.

[1 mark] Cold: basic facilities; more setup; slower and less expensive.

[1 mark] Hot: compatible equipment/software available; relatively fast; more expensive.

[1 mark] Mirrored: closely replicated primary site/data; very fast; costly.

[1 mark] Recovery selection depends on criticality and budget; mirroring does not replace backups.

Exam note: Avoid saying recovery is always instantaneous.

Q09. 4 marks — List the six BCP preparation phases in order and explain why Testing and Maintenance are needed.

[2 marks] Project Initiation → Business/Risk Analysis → Design & Development → Implementation → Testing → Maintenance (credit ordered phases).

[1 mark] Testing validates planned procedures and identifies weaknesses.

[1 mark] Maintenance updates the plan when systems, people and threats change.

Exam note: A plan that is never tested may fail in a real incident.

Q10. 4 marks — Given ACL rules in order: 1 Deny Internal → 203.0.113.50; 2 Allow Internal → TCP 80; 3 Deny Any. Decide (a) Internal HTTP to 203.0.113.50 and (b) Internal HTTP to 198.51.100.8, justifying first match.

[1 mark] Request (a) matches Rule 1.

[1 mark] It is DENIED even though Rule 2 could permit TCP 80.

[1 mark] Request (b) does not match Rule 1; matches Rule 2.

[1 mark] It is ALLOWED; the first matching rule determines the action.

Exam note: Check in rule order; never skip specific deny.

Q11. 3 marks — Define DMZ and briefly distinguish IDS from IPS in a public-web-service deployment.

[1 mark] DMZ isolates public services from sensitive internal network resources.

[1 mark] IDS detects suspicious activity and alerts.

[1 mark] IPS can actively block or interrupt detected malicious traffic.

Exam note: Three concise points suffice for this 3-mark item.

PART 3 • Essay / integrated scenario model answers

Q01. University access & identity (7 marks) — 7 marks

Scenario: A university introduces a single-login portal for students, lecturers and administrators. Students must not edit marks; lecturers can edit assigned-course results; account administrators manage users. Some student passwords have been stolen. Design a suitable access-control and authentication solution.

[1 mark] Choose RBAC and name at least Student, Lecturer and Admin roles.

[1 mark] Allocate least-privilege permissions; Student read own results, Lecturer edit assigned-course results, Admin manage accounts.

[1 mark] Enforce per-resource/per-record authorization after authentication.

[1 mark] Introduce MFA with distinct factors (password + possession/security key).

[1 mark] Use salted slow password verifiers and breached-password response.

[1 mark] Use SSO cautiously with central monitoring and resilience.

[1 mark] Log significant permission changes and suspicious access; separation of duties for sensitive changes.

Sinhala reasoning: University jobs අනුව RBAC; stolen passwords නිසා MFA; successful login එකෙන් student කෙනෙකුට marks edit අවසර නැහැ.

Q02. Disaster recovery of an online hospital (7 marks) — 7 marks

Scenario: A hospital data center is damaged by flooding. Emergency clinicians need continued access to essential records. The hospital can fund a well-prepared recovery site but wants to prevent recent data loss. Recommend an integrated DRP and BCP strategy.

[1 mark] Identify Availability and business impact on clinical services.

[1 mark] Provide an Alternate Mode for essential clinical operations, defining SDO.

[1 mark] Select Hot/Mirrored Site based on recovery requirements and funding.

[1 mark] Use appropriate replication/remote journaling to reduce data loss.

[1 mark] Maintain separate protected backups and verify restoration.

[1 mark] Define incident declaration, responsibilities and safety/evacuation procedures.

[1 mark] Conduct periodic recovery testing and plan maintenance.

Sinhala reasoning: BC = doctors ලට essential care continue; DR = data center restore. Mirrored copy එක corruption propagate කළ හැකි නිසා protected backups අවශ්‍යයි.

Q03. Network breach defense and incident handling (8 marks) — 8 marks

Scenario: A company hosts a public website, an email server and an internal payroll database. An external attacker probes internal ports while suspicious traffic appears on multiple systems. Design a network-security architecture and incident-monitoring strategy.

[1 mark] Place public web and email services in a DMZ.

[1 mark] Keep payroll database in protected internal segment behind restrictive firewall.

[1 mark] Define ACL allow rules for only required services (e.g., TCP 80 web, TCP 25 SMTP in lecture context).

[1 mark] Add Stealth Rule for firewall management and final Cleanup/Default-Deny rule.

[1 mark] Use Stateful Packet Inspection for valid return traffic.

[1 mark] Use IDS/IPS for detection and appropriate blocking.

[1 mark] Use SIEM to correlate logs from firewalls, hosts and applications.

[1 mark] Use anti-spoofing, least privilege, patching and monitoring; a VPN can protect office-to-office links if required.

Sinhala reasoning: One firewall alone නොව DMZ + ACL + Stateful + IDS/IPS + SIEM layered defense එක exam එකට justify කරන්න.

Essay self-check: improve your answer

Answer එක ලියපු පසු පහත checklist එක අනුව self-mark කරන්න. Part 3 එකේ theory term එකක් ලිව්වා කියලා විතරක් සම්පූර්ණ marks ලැබෙන්නේ නැහැ; scenario එකට සම්බන්ධ explanation එකක් අවශ්‍යයි.

- Did I name the correct security control or mechanism?
- Did I explain why it fits this specific scenario?
- Did I distinguish authentication, authorization, prevention and recovery?
- Did I avoid promising that any one control stops every attack?
- Did I write in short English paragraphs or organized points?

Write one improvement for each essay

Q1: _____

Q2: _____

Q3: _____

LAST-MINUTE RECALL

Final Revision Sheet

විභාගයට කලින් නැවත මතක් කරගත යුතු theory comparisons සහ diagrams

Term	One-line English recall
Access Control	Prevent unauthorized use of a resource.
Authentication	Verify a claimed identity.
Authorization	Determine what an identity is allowed to do.
DAC	Discretionary sharing based on authorized owners/ identities.
MAC (Week 9)	Mandatory Access Control using labels and clearances.
RBAC	Assign permissions to roles.
ACL	Object-associated list of subjects and rights.
Capability	Unforgeable resource-authority token/reference.
Least Privilege	Grant minimum necessary permission.
SoD	Divide sensitive tasks between people.
Dual Control	Require multiple authorized persons for a critical action.
MFA	Multiple independent factor categories.
SSO	Central sign-in to multiple associated services.
Salt	Unique random input for password hashing.
Challenge–Response	Fresh nonce plus secret-dependent response.
DRP	Restore damaged systems and infrastructure.
BCP	Maintain essential operations during disruption.
SDO	Service target while operating in Alternate Mode.
Cold / Hot / Mirrored	Basic facility / prepared site / closely replicated site.
Stealth / Cleanup	Protect firewall itself / deny unmatched traffic.
Stateful Firewall	Tracks authorized session states.
DMZ	Separates public-facing and internal networks.
IDS / IPS	Detect and alert / detect and prevent.

Term	One-line English recall
SIEM	Correlate security logs/events.
UTM	Integrated gateway security functions.
VPN	Protected tunnel across a shared/untrusted network.

Four must-draw diagrams

Access Matrix

Rows: users • Columns: objects • Cells: R / W / X / —

Password Verification

Password → salted slow hash → comparison

Recovery Timeline

Failure → Interruption → Alternate Mode → Restoration

DMZ / Firewall

Internet → Outer Firewall → DMZ → Inner Firewall → Internal LAN

Fast, no-calculator mini practice

Q1. A manager issues Read access only to a file. May Write be assumed?

> **Answer:** No. Check explicitly granted rights.

Q2. Is a PIN + password definitely two-factor?

> **Answer:** No. Both are knowledge factors.

Q3. A system fails at 09:00 and alternate service starts at 10:15. How long is interruption?

> **Answer:** 1 hour and 15 minutes.

Q4. A packet first matches a Deny rule and later matches Allow. What happens?

> **Answer:** Deny under the lecture's first-match ACL model.

Q5. Normal network traffic triggers an IDS attack alarm. TP / FP / TN / FN?

> **Answer:** False Positive (FP).

Source map and scope

Lecture sources: Week 9 – Access Control (slides 3–22); Week 10 – User Authentication (slides 3–25); Week 11 – DRP & BCP for Risk Management (slides 3–20); Week 12 – Firewalls, ACLs & Network Security (slides 5–36).

Tutorial sources: ACCESS CONTROL; USER AUTHENTICATION; DRP & BCP tutorials from the uploaded DOCX collection.

Past papers used for adapted exercises: IAS_2022_Nov.pdf (Questions 3–4); IT3070 – Information Assurance and Security.pdf (Questions 3–4, older paper); IT3070 –Information Assurance & Security (1).pdf (Questions 3–4, later paper). In the practice clinic, cases are paraphrased and answers are newly written.

Course-aligned terminology: Some slide details are simplified, and a few examples concern older authentication or firewall practices. Where implementation guidance needed a qualification (password hashing, session-state validation, token secrecy, MTO terminology, mirroring), it is explicitly marked as “Practical clarification”, “Terminology caution”, or “Lecture model vs implementation detail”.

Scope: This booklet focuses on weeks 9–12. The real examination may cover the entire module, so it should accompany your earlier Weeks 1–8 revision.

Final study routine

Round 1: Read one chapter and trace its diagrams. **Round 2:** Close the chapter; answer its checkpoint questions from memory. **Round 3:** Solve past-paper-adapted scenarios. **Round 4:** Attempt the 100-mark mock without notes. **Round 5:** Mark with the answer guide and revise weak topics.

Before you open the real exam – five common traps

If the scenario says…	Your first thought should be…
A user logged in but cannot edit a record	Authorization / RBAC, not authentication
The same password is used with different salts	Distinct verifiers; not additional password entropy
A record of yesterday’s valid response is resent	Replay; require a fresh nonce
Two people must approve the same action	Dual Control, not merely different workflow steps
A catch-all deny appears above the allow	Rule-order error in a first-match ACL
A public website is beside an internal database	Use DMZ and restrictive inner firewall
Primary database restoration vs backup-site operation	DR = restore; BC = continue

Self-marking record

Section	Maximum marks	Your score
Part 1: 35 short questions	35	_____ / 35
Part 2: 11 structured questions	43	_____ / 43
Part 3: 3 scenario essays	22	_____ / 22
TOTAL	100	_____ / 100

END OF GUIDE • IT3070 INFORMATION ASSURANCE & SECURITY